

CWE AI Working Group: New Entry Development

Meeting Minutes

March 28, 2025

Attendance

- Chris Coffin
- Dave Morse
- Sazadur Rahman
- Sven Cattell
- Trent Holmes
- Kyle Norland
- Lee Szilagyi
- Steve Christey
- Mirza Ali
- Lily Wong
- Marissa Dotter
- Chris Gourley
- Erick Galinkin
- Joseph George
- Martin Hodo
- Joao Galego
- Michael Simon
- Sundeep Rana

Agenda

- Status Updates
- Preview: Changes To CWE-1039
- Detailed Discussion: New Entry for Inference Parameters

Meeting Notes:

Status Updates:

- **Introduction of New Members:** Steve welcomed new members Trent, Lee, and Sazadur to the meeting, allowing them to introduce themselves and share their backgrounds and interests in security research and AI.
 - **Trent's Introduction:** Trent, who works for Trend Micro, introduced himself as new to security research and expressed his eagerness to learn and contribute to the group.
 - **Lee's Introduction:** Lee Szilagyi, who has previously worked on AI for the White House and as a global director of AI security for a pharma company,

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

introduced himself. He mentioned his current role at MITRE and his interest in the group's work.

- **Sazadur's Introduction:** Sazadur Rahman, a faculty member at the University of Central Florida and former Intel employee, introduced himself. He expressed his interest in learning about CWE certification and contributing to the group's efforts.
- **CWE Release and Repository Update:** Steve announced the upcoming CWE release on April 3rd, which is intentionally timed before VulnCon 2025 (April 7 – 10). He also mentioned that the Content Development Repository (CDR) will be public.
- **Garak Open Source Project:** Erick shared an update on the Garak open-source project, an LLM vulnerability scanner, which now incorporates CWE as a reference point for tagging. Erick mentioned that the project historically tagged content with various taxonomies, including OWASP's LLM Top Ten. This change is intended to help non-security people understand CWE's relevance in their reports.

CWE-1039 Modifications: Steve provided an overview of the modifications made to CWE-1039, which was last updated in 2018. Marissa contributed significantly to these changes, adding mitigations and detection methods.

- **Extended Description:** The extended description of CWE-1039 has been expanded to include automated cyber defense, chatbots, LLMs, and generative AI. This expansion aims to address a broader range of technologies affected by adversarial perturbations.
- **Role of Perturbations:** Steve mentioned that the updated entry now includes the role of perturbations in attacks such as jailbreaks, although the community still needs to better understand the weaknesses enabling these attacks.
- **Mitigations Added:** Marissa added several mitigations to CWE-1039, including model pruning and compression, adversarial training, model hardening, and improving robustness using model ensembling techniques.
- **Detection Methods:** Steve highlighted the addition of detection methods to identify weaknesses, although he noted that this was not the focus of the current discussion.
- **Mechanistic Interpretability:** A discussion about mechanistic interpretability occurred between Kyle, Steve, Marissa, and Erick. Marissa was not sure if it fit within the scope of CWE-1039. Kyle and Marissa agreed that interpretability was still in the research stages, with Steve noting that one of CWE's primary audiences was

developers looking for practical guidelines. Erick added the research was emerging and that it might not make sense to add as of now.

Detailed Discussion: New Entry for Inference Parameters: Steve led a discussion on the proposed new entry for inference parameters, focusing on common consequences, modes of introduction, and mitigations. The group provided input on various aspects, including the importance of dynamic analysis for detecting weaknesses.

- **Common Consequences:** Steve discussed the common consequences of insecure inference parameters, such as generating inaccurate, misleading, or nonsensical information. The group noted that these consequences do not map cleanly to CWE's current technical impact model.
- **Modes of Introduction:** The group identified three modes of introduction for the weakness: during model training, hyperparameters set without appropriate validation, and unconstrained API calls. These modes highlight different stages where weaknesses can be introduced.
- **Mitigations:** Steve outlined several mitigations, including robust parameter tuning, extensive testing and validation, and implementing feedback mechanisms for assessing and adjusting model performance. The group agreed that these mitigations are appropriate for various phases of implementation.
- **Dynamic Analysis:** The group emphasized the importance of dynamic analysis for detecting weaknesses in inference parameters. Methods such as running models against test sets and comparing them to other models in their lineage were discussed.
- **Real-World and Demonstrative Examples:** The group discussed the need for real-world and demonstrative examples to illustrate the weaknesses related to inference parameters. Kyle and Lily agreed to collaborate with Steve to develop a theoretical example involving a robot with inappropriate parameters.

Next Steps and Future Meetings: Steven outlined the next steps, including the publication of CWE 4.17 on April 3rd and the upcoming subgroup meetings. Erick mentioned a paper on multi-agent security and encouraged feedback from the group.

- **Upcoming Meetings:** Steven announced the dates for the next subgroup meetings, with the modifications subgroup meeting in two weeks and the new entry subgroup meeting on April 25th.

Action Items:

- **Mechanistic Interpretability:** Follow up with Marissa on the use of model ensembling techniques for improving robustness. (Steve)
- **Inference Parameters Example:** Collaborate to flesh out a general example for the CWE entry on inference parameters. (Steve, Lily, Kyle)